

Grading an Autonomous SOC Investigation Against 14 Metrics

Subject: Incident **6bc323a620a6443f** -- CloudTrail logging disablement, Tier 3 autonomous investigation, verdict SUPPORTED at 80% confidence.

SOURCE DOCUMENT

4-page incident report,
10 queries, 73s runtime

SCALE

0 - 100 per metric,
weighted composite

SAMPLE

n = 1 incident
(see limitations, p8)

ASSESSED

21 August 2026

OVERALL WEIGHTED SCORE

33.2

FAILING

Performs the motion of the discipline, fails its substance. Robust across every framing tested: 37.2 charitable, 29.9 harsh, 33.9 unweighted. No reasonable lens moves this document out of the FAILING band.

33.2



THE THREE FINDINGS THAT GOVERN EVERYTHING ELSE

01 The MITRE technique ID is fabricated.

T1685.002 does not exist in ATT&CK Enterprise. The correct technique for stopping or deleting CloudTrail is **T1562.008 -- Impair Defenses: Disable or Modify Cloud Logs**. The invalid ID propagates through the rule name, the MITRE Mapping block, all three Detection Opportunities, and Lessons Learned. T1087.004 in the same document *is* valid, which means the system is format-matching identifiers, not validating them.

02 A corrupted account ID sits inside the evidence.

Everywhere else the account is 210987654321. In H1's supporting evidence on page 2 it is `arn:aws:sts::210087654321:assumed-role/...` -- a hallucinated identifier in the load-bearing evidence string of the hypothesis the system chose to support.

03 The report contradicts itself on whether corroboration exists.

Correlation Analysis: *"No related activity was found."* Disposition: *"corroborated by 1 related event."* H1: *"R-T1087.004-NET-002 fired."* FP check 4: *"get_corroborating_entities did not return other corroborating verdicts."* Four sections, three answers. The weakest framing is buried deepest; the strongest is on page 1.

01 Method and grading bands

Each of the fourteen requested metrics is scored 0-100 against a single question: *would a competent senior analyst, reading only this document, be able to trust and act on that dimension of it?* Scores are assigned per-document, not per-product. Bands are defined before scoring, and every score below carries a specific, quotable anchor from the source report rather than an impression.

RANGE	BAND	OPERATIONAL MEANING	COUNT
75 - 100	STRONG	Ships as-is; passes senior analyst review unchanged	0
60 - 74	SUPERVISED	Usable, but an analyst must verify before acting	1
45 - 59	UNRELIABLE	Structure present, substance not dependable; analyst redoes the work	2
30 - 44	FAILING	Performs the motion of the discipline, fails its substance	5
15 - 29	SEVERE	Defective to the point of being actively misleading	5
0 - 14	ABSENT	Capability missing, or its output is harmful	1

Distribution: six metrics land in SEVERE or worse, five in FAILING, two UNRELIABLE, one SUPERVISED. **Nothing clears 60.** Median 32, mean 33.9, range 12-60.

02 Scorecard

#	METRIC	SCORE		BAND	WT	CONTRIB.
1	Reasoning	42		FAILING	10	4.2
2	Investigation	31		FAILING	11	3.4
3	Correlation	27		SEVERE	8	2.2
4	Hypothesis management	38		FAILING	7	2.7
5	False-positive analysis	60		SUPERVISED	6	3.6
6	Explainability	52		UNRELIABLE	8	4.2
7	Detection engineering	36		FAILING	2	0.7
8	Recursive investigation	48		UNRELIABLE	5	2.4
9	Evidence quality	26		SEVERE	11	2.9
10	Confidence calibration	28		SEVERE	9	2.5
11	Cross-platform investigation	18		SEVERE	4	0.7
12	Response automation	12		ABSENT	7	0.8
13	Data integrity	23		SEVERE	10	2.3
14	Production readiness	33		FAILING	2	0.7
WEIGHTED COMPOSITE					100	33.21

Contribution = score x weight / 100. Weighting rationale is derived on page 5. The dashed marker on each bar sits at 60 -- the trust threshold.

03 Findings by metric

01 Reasoning

 42 FAILING

Direction correct, narrative coherent. But the load-bearing arguments are absence-of-evidence, plus one wholly unsupported baseline claim ("stopping CloudTrail logging is not expected for routine operations") for which no baseline was ever queried. Verdict history returns verdicts, not activity norms.

02 Investigation

 31 FAILING

Never establishes whether logging is *still* disabled six days on -- the single most important operational fact in a logging-disablement incident. Never resolves whether DeleteTrail occurred despite it being in rule scope. No trail name, no region, no event ID. Never enriches the source IP it recommends enriching. Every search capped at 30 minutes.

03 Correlation

 27 SEVERE

Renders the rule's correlation *template* -- discovery, privilege-escalation, collection, exfiltration -- in the same visual language as observed findings. No chain leg was ever queried. A reader skimming page 1 concludes exfiltration was observed. Four sections give three different answers on whether corroboration exists at all.

04 Hypothesis management

 38 FAILING

Two hypotheses in a forced binary, confidences summing to exactly 100, asserting an exhaustiveness that does not hold. No infrastructure-as-code branch, no accident branch, and no compromised-credential-versus-insider split -- the one branch that determines the entire response path. The word "attacker" appears throughout without that distinction ever being made.

05 False-positive analysis

 60 SUPERVISED

The strongest section. Four named checks, each with written reasoning, and check 4 honestly downgrades the system's own corroboration claim. Held at the band floor by circular reasoning in check 1, by check 2 restating the hypothesis rather than testing it, and by a "Fail" label that inverts intuition at 2am.

06 Explainability

 52 UNRELIABLE

Readable, confidences stated, rejection rationale explicit -- above the commercial bar. But zero raw records, a one-entry timeline beneath a multi-stage chain claim, and not one assertion an analyst can verify without re-querying from scratch. "7 records reviewed" -- which seven is never disclosed.

07 Detection engineering

 36 FAILING

Three suggestions, none implementable: no query logic, no field mappings, no thresholds, no false-positive cost. Suggestion 2 proposes building a correlation feature the platform is already running on page 1. Suggestion 1 proposes a window tighter than the one that just failed. All three filed under an invalid technique ID.

03 Findings by metric (continued)

08 Recursive investigation		48 UNRELIABLE
The verdict-history pivot is the single best move in the document and is what justified the escalation: it correctly establishes a 2m37s precedence. Then it halts at one hop -- no recursion into the discovery verdict's own evidence, no pivot on source IP, no pivot on other principals assuming the same role.		
09 Evidence quality		26 SEVERE
A corrupted AWS account ID sits inside the supported hypothesis's own evidence string. A fabricated MITRE ID is cited four times. A byte-identical duplicate tool call inflates the query count. Two calls produce output that appears nowhere. One qualifier is stale, one silently abandoned. Of "10 queries", roughly five did real work.		
10 Confidence calibration		28 SEVERE
0.35 to 0.80 with no stated method. Two unrelated confidence figures displayed adjacently on page 1 with no explanation of their relationship. And 80% at HIGH severity resolving to "no actions warranted" means either the action threshold is broken or the number is decorative. Both readings are disqualifying.		
11 Cross-platform investigation		18 SEVERE
same_asset_only:True on every search -- blindness by configuration -- then reported as "no related activity was found." sensor:cdr exclusively. No identity-provider query despite a federated SSO role, which is precisely where compromise-versus-insider resolves. Lessons Learned reframes this limitation as a feature.		
12 Response automation		12 ABSENT
No action, no containment, no session revocation. Across three follow-up recommendations it never once says to re-enable CloudTrail. The organisation's audit logging is off, the report knows it, and the remediation is simply absent. The only response-adjacent sentence is a capability disclaimer glued mid-way into an investigation recommendation.		
13 Data integrity		23 SEVERE
Sixteen distinct defects logged across four pages: fabricated identifier, corrupted ARN, duplicate call, stale qualifier state, four-way self-contradiction, an RFC 5737 documentation address handled as a live indicator, and byte-identical copy-paste between Disposition and Trigger. No validation layer is evident anywhere in the pipeline.		
14 Production readiness		33 FAILING
Credit for a 73-second turnaround, clean structure, and genuine self-criticism. Blocked by four credibility-enders an analyst hits inside two minutes, and by a summary page that contradicts its own body -- which destroys precisely the time saving the product exists to create.		

04 The overall score, derived

A composite is only worth stating if it survives being attacked. This one was computed four ways -- unweighted, weighted by operational consequence, charitably (forgiving everything attributable to the demo environment), and harshly (grading as production tooling in a regulated setting). The four results are given below.

WEIGHTING MODEL

WT	METRICS	RATIONALE
11	Evidence quality; Investigation	Everything else is downstream of whether the facts are real and whether the system actually looked.
10	Data integrity; Reasoning	One fabricated identifier voids the document. The inference chain is the product.
9	Confidence calibration	This is the number that decides whether a human gets woken up.
8	Correlation; Explainability	Chain construction, and whether an analyst can verify any of it independently.
7	Response automation; Hypothesis management	What the system does, and whether it considered the branch that determines what to do.
6	False-positive analysis	The principal labour saving an autonomous tier actually offers a SOC.
5	Recursive investigation	The agentic differentiator versus a static SOAR playbook.
4	Cross-platform investigation	High ceiling, but gated on integrations rather than on reasoning quality.
2	Detection engineering; Production readiness	Secondary output; and a meta-metric that partly double-counts the rest.

FOUR FRAMINGS

FRAMING	SCORE	WHAT IT ASSUMES
Charitable	37.2	Forgives every defect plausibly attributable to a sparse demo tenant: empty context store, synthetic telemetry, thin correlation surface. Maximum benefit of the doubt.
Unweighted mean	33.9	All fourteen metrics counted equally. No judgement applied about which matter more.
Weighted (headline)	33.2	Weighted by operational consequence per the model above. This is the reported figure.
Harsh	29.9	Graded as production tooling in a regulated environment, where a fabricated framework identifier and a corrupted account ID in evidence are individually disqualifying.

The spread is the finding: 29.9 to 37.2.

Weighting moves the composite by **less than one point** (33.9 unweighted to 33.2 weighted). Maximum charity buys four points and still lands eleven points short of UNRELIABLE. If this deficit were concentrated in one or two subsystems, re-weighting would swing the number by ten or more. It does not. **The failure is broad-spectrum, not localised** -- which rules out fixing it by patching a single component, and means no procurement argument about metric priority can rescue the result.

THE DECISIVE RATIO

Split the fourteen metrics into the layer that *presents* reasoning and the layer that *supplies* it. Framework layer -- false-positive analysis, explainability, hypothesis management, reasoning -- averages **48.0**. Substance layer -- evidence quality, data integrity, investigation, correlation, cross-platform, calibration, response -- averages **23.6**. The scaffolding scores **2.04x** the facts beneath it.

That configuration is worse than uniform mediocrity. A uniformly weak system announces itself on the first read. This one reads authoritative -- structured hypotheses, cited disconfirming evidence, named checks, explicit confidence figures -- while resting on identifiers it invented and searches it scoped to return nothing. It is calibrated to survive exactly the kind of review that a buyer performs, and to fail the kind that an incident performs.

05

The structural defect: confidence rises as investigation narrows

Every individual defect in this report is downstream of one mechanism. It is not a tuning error; it is the direction of the architecture's incentive gradient, and it is the single most important thing in this assessment.

STEP	WHAT HAPPENS	EVIDENCE IN THE SOURCE
1	Rule fires at low confidence.	R-T1685.002-NET-001 matched, confidence 0.35.
2	Investigation scopes itself narrowly.	within_seconds_of_anchor:1800 on all searches; same_asset_only:True; sensor:cdr only.
3	Narrow scope returns nothing.	"No evidence of a replacement CloudTrail..."; "No active change ticket was found."
4	Null results are logged as disconfirming evidence.	All three of H2's disconfirming items are null results. Three of four FP checks are absence-based.
5	The benign hypothesis collapses.	H2 rejected at 20%. H1 rises to 80%.
6	Verdict issues at high confidence.	VERDICT: SUPPORTED (80%), HIGH SEVERITY.

The loop: the less thoroughly it searches, the more confident it becomes.

Widen the window from 30 minutes to 6 hours and a Terraform reconciliation appears, H2 survives, and confidence falls. Drop same_asset_only and cross-asset context appears. **The system's certainty is inversely proportional to its investigative effort.** The 80% is not merely overstated -- it is *manufactured* by the investigation's weakness. Roughly one positive observation (a 2m37s precedence) carried 45 points of confidence, assisted by six absences.

AND THE FALLACY HAS ALREADY BEEN PROMOTED TO DOCTRINE

"The absence of expected benign activity (e.g., re-enabling logging, change ticket) can be as strong an indicator of malicious intent as the presence of outright malicious activity."

-- Lessons Learned, page 3, verbatim

That is argument from ignorance, written down as a reusable lesson and carried forward into future investigations. It is already being converted into production content: Detection Opportunity 1 proposes a rule that *raises severity when no CreateTrail or StartLogging event is found* -- codifying the same inference into a detection that will fire on every legitimate maintenance action outside its window.

The system also identified its own epistemic limit and then overrode it. From the H2 rejection rationale: *"While the tools couldn't definitively prove the absence of any planned change..."* -- followed immediately by rejection anyway. It knew. It proceeded.

At scale, this is an alert-fatigue engine wearing an AI SOC badge.

A pipeline that escalates 0.35 signals to 0.80 verdicts on the strength of null results will, at production alert volumes, systematically manufacture high-confidence conclusions from low-confidence inputs. That inverts the entire value proposition of an autonomous tier, whose purpose is to *remove* uncertain alerts from the human queue, not to launder them into certain ones.

06 Root causes and defect register

Sixteen logged defects reduce to four root causes. Three are cheap to fix. One is architectural.

ID	ROOT CAUSE	SEV	FIX COST	DEFECTS
RC-1	No output validation layer. Identifiers are format-matched, never checked against ground truth.	High	Low	D-01, D-02, D-09, D-13
RC-2	No investigation state machine. Each section regenerates prose independently instead of rendering from one canonical state object.	High	Medium	D-03, D-10, D-15
RC-3	Scoping defaults biased toward null results, which then raise confidence. Feeds the loop on page 6.	Critical	Med-High	D-04, D-07, D-11, D-12, D-16
RC-4	No confidence-to-action policy. High confidence terminates in no action and no remediation.	High	Low	D-05, D-06

DEFECT REGISTER

ID	DEFECT	WHERE	SEV
D-01	MITRE technique T1685.002 does not exist; correct ID is T1562.008	p1, p3	CRIT
D-02	Corrupted account ID in H1 evidence: 210087654321 vs 210987654321	p2	CRIT
D-03	Corroboration contradicted across four sections, three different answers	p1-p3	CRIT
D-04	Correlation template rendered in the visual language of observed findings	p1	CRIT
D-05	Never recommends re-enabling CloudTrail; no remediation of the logging gap	p3	CRIT
D-06	80% confidence at HIGH severity resolves to "no actions warranted"	p4	CRIT
D-16	Argument from ignorance encoded as Lessons Learned and as a proposed detection	p3	CRIT
D-07	Current state of logging never established despite a six-day event-to-report gap	all	HIGH
D-08	DeleteTrail is in rule scope but never resolved anywhere in the narrative	p1, p2	HIGH
D-09	Byte-identical duplicate search_alert_pool call inflating the query count	p4	HIGH
D-10	Qualifier q1 stale after being answered; q2 never queried and silently dropped	p1	HIGH
D-11	same_asset_only:True on all searches, then reported as "no related activity"	p4	HIGH
D-12	No identity-provider query despite a federated SSO role being the subject	all	HIGH
D-13	RFC 5737 documentation address (198.51.100.77) handled as a live indicator	p2, p3	MED
D-14	No trail name, region, event ID, or raw record anywhere in the document	all	MED
D-15	Disposition and Tier-3 Trigger text byte-identical; trigger stage adds no reasoning	p2	LOW

07 Remediation trajectory

Fixing the four root causes moves nine of fourteen metrics. Projections are deliberately conservative: no metric is credited above the SUPERVISED floor, since none of these fixes adds telemetry coverage or surfaces raw evidence.

FIX	METRICS MOVED	FROM	TO
RC-1 Validate identifiers and ARNs against ground truth before render	Data integrity, Evidence quality, Detection engineering	23 / 26 / 36	55 / 42 / 48
RC-2 Single canonical state object; render all sections from it	Correlation, Explainability, Production readiness	27 / 52 / 33	45 / 62 / 52
RC-3 Widen windows; distinguish "no match" from "source empty" from "not queried"	Investigation, Reasoning, Confidence calibration	31 / 42 / 28	48 / 58 / 50
RC-4 Mandatory remediation block above the confidence threshold	Response automation, Hypothesis management	12 / 38	55 / 42

Projected composite after all four: **50.8** -- still short of shipping, but across the only boundary that matters commercially: from *actively misleading* to *supervised-usable*. Cross-platform coverage (18) and raw-evidence surfacing are untouched by all four fixes; they need integration work, not logic changes, and are the next tranche.

08 Verdict

The conclusion this report reaches is probably correct. StopLogging two minutes and thirty-seven seconds after cloud account discovery by the same principal, with no replacement trail, is genuinely suspicious; a competent human analyst escalates it too.

That is the most dangerous possible state for a system that reasons this way. Being right for structurally unsound reasons means the defects survive every demonstration and surface only on the case where the answer is wrong -- which is precisely the case where the cost of being wrong is highest. A system that manufactures confidence from absence will be right whenever the absence is meaningful and catastrophically wrong whenever it is merely unqueried, and it has no way to tell those apart.

The skeleton is worth keeping and is ahead of much of the commercial field: named false-positive checks, explicit competing hypotheses with cited disconfirming evidence, recursive verdict-history pivots, and a 73-second turnaround. The evidence layer beneath that skeleton is not yet trustworthy. A fabricated framework identifier and a corrupted account ID inside an evidence string will end an evaluation in a regulated environment in under two minutes, no matter how good the reasoning above them looks.

33.2 / 100 -- FAILING. The architecture is not the problem. The facts are.

Four fixes, three of them cheap, move this to roughly 51. None of them require rethinking the approach. What they require is that the system stop treating its own unasked questions as answers.

LIMITATIONS OF THIS ASSESSMENT

- **n = 1.** Scores describe this document, not the product; a second incident could move any row materially. The Lessons Learned entry quoted on page 6 is, however, explicit evidence of intended future behaviour.
- **Exported PDF only.** No access to raw tool outputs, rule definitions, context-store contents, or platform configuration. Some defects attributed to reasoning may be rendering artifacts of the report generator.
- **Demo tenant.** "Confidential -- prepared for demo-tenant" is stamped on every page; sparse context-store data may be an environment property rather than a product defect. The charitable framing forgives this in full and still lands at 37.2, inside FAILING.
- **MITRE validity** checked against ATT&CK Enterprise. T1087.004 confirmed valid. T1685.002 has no entry; T1562.008 is the correct mapping for the described behaviour.